



KAPASA MAKASA UNIVERSITY

SCHOOL OF APPLIED SCIENCES

DEPARTMENT OF INFORMATION COMMUNICATION TECHNOLOGY

RESEARCH TOPIC

Design and Development of a modular AI-powered web vulnerability scanner

BY

Evans Bwalya (20231947)

Asneli Banda (20231926)

BSc CYBER SECURITY

INTRODUCTION & BACKGROUND STUDY

- In the ever-evolving landscape of information technology, ensuring the security and resilience of digital assets is paramount.
- Vulnerability scanners play a crucial role in this endeavor by systematically and comprehensively examining computer systems, networks, and applications to identify potential weaknesses and security gaps.
- With the growth of online services, organizations depend heavily on web-based systems to manage sensitive data and critical operations.
- Cyber-attacks on web applications have increased, with over 70% of modern attacks targeting them
- Traditional vulnerability scanners rely on static rules and signatures, making them ineffective against dynamic and complex applications.
- Manual penetration testing is accurate but time-consuming, costly, and requires specialized expertise
- Large Language Models (LLMs) provide a new solution by mimicking human reasoning to identify vulnerabilities more effectively

PROBLEM STATEMENT

- ❖ many traditional scanners have limited adaptability to modern web applications written in heavy languages like JavaScript, php, etc. and struggle to detect complex, context dependent security flaws, miss logic flaws and novel attacks. most scanners are not modular and fail to support seamless integration of intelligent components such as large language models (LLMs).

RESEARCH OBJECTIVES

General Objectives

- ❖ To develop a modular, a modular AI-powered web scanner that leverages large language models (LLMs)

Specific Objectives

- ❖ Integrate LLMs (OpenAI/Anthropic) for context-aware scanning.
- ❖ To develop a modular system architecture that supports intelligent discovery, validation, crawling, payload generation and traffic monitoring
- ❖ To generate comprehensive, human readable vulnerability reports that include technical findings, evidence, and remediation recommendations

RESEARCH QUESTION

- I. How can large language models (LLMs) be leveraged to simulate human reasoning for identifying and validating web applications vulnerabilities?
- II. How effective is the integration of intelligent fuzzing and context aware payload generation in detecting complex and evolving threats
- III. Can automated exploit verification using AI significantly reduce false positives in security reporting

Literature Review

Building on Existing Research

Study (Source)	Contribution	Research Gap Addressed
YURASCANNER [3]	LLMs for task-driven XSS scanning	Limited to XSS; Cloud-only LLM. EvDeX is multi-vulnerability & hybrid.
RealVul [4]	LLM fine-tuned for PHP vulnerabilities	PHP-specific. EvDeX is language-agnostic.
Client-Side LLM [6]	Privacy-focused in-browser analysis	Only URL scanning. EvDeX provides full app scanning
Multi-Scanner [8]	Combining tools improves coverage	No AI/LLM integration. EvDeX is natively intelligent.

Methodology

Requirement analysis

- ❖ This study adopts a comparative review methodology, synthesizing empirical findings from prior research to evaluate the capabilities and limitations of existing web vulnerability scanners.[6]
- ❖ **Scanner Selection:** Commercial (Acunetix, Burp Suite) and open-source (OWASP ZAP, Arachni, Skipfish) scanners were selected based on their prevalence in industry/academia and coverage of OWASP Top 10 vulnerabilities, as reported in existing literature [6].
- ❖ **Evaluation Metrics & Results:** Performance metrics such as Precision, Recall, Youden Index, JS support, and WASSEC scores were extracted from the published study to identify critical gaps in current tools.
- ❖ **Outcome:** This comparative review highlights the need for a modular AI Powered web vulnerability scanner called EvDeX-Scan, designed to address limitations such as lack of context-aware analysis and incomplete JS support.

PROPOSED SYSTEM

Adaptive fuzzing with AI-generated payloads

- ❑ our scanner will generate thousands of payloads using AI instead of relying only on static, predefined payload lists.
- ❑ AI will adaptively craft payloads based on the website's technology stack, detected frameworks, and server responses.
- ❑ The system will then analyze the responses and check if the input caused any unusual behavior

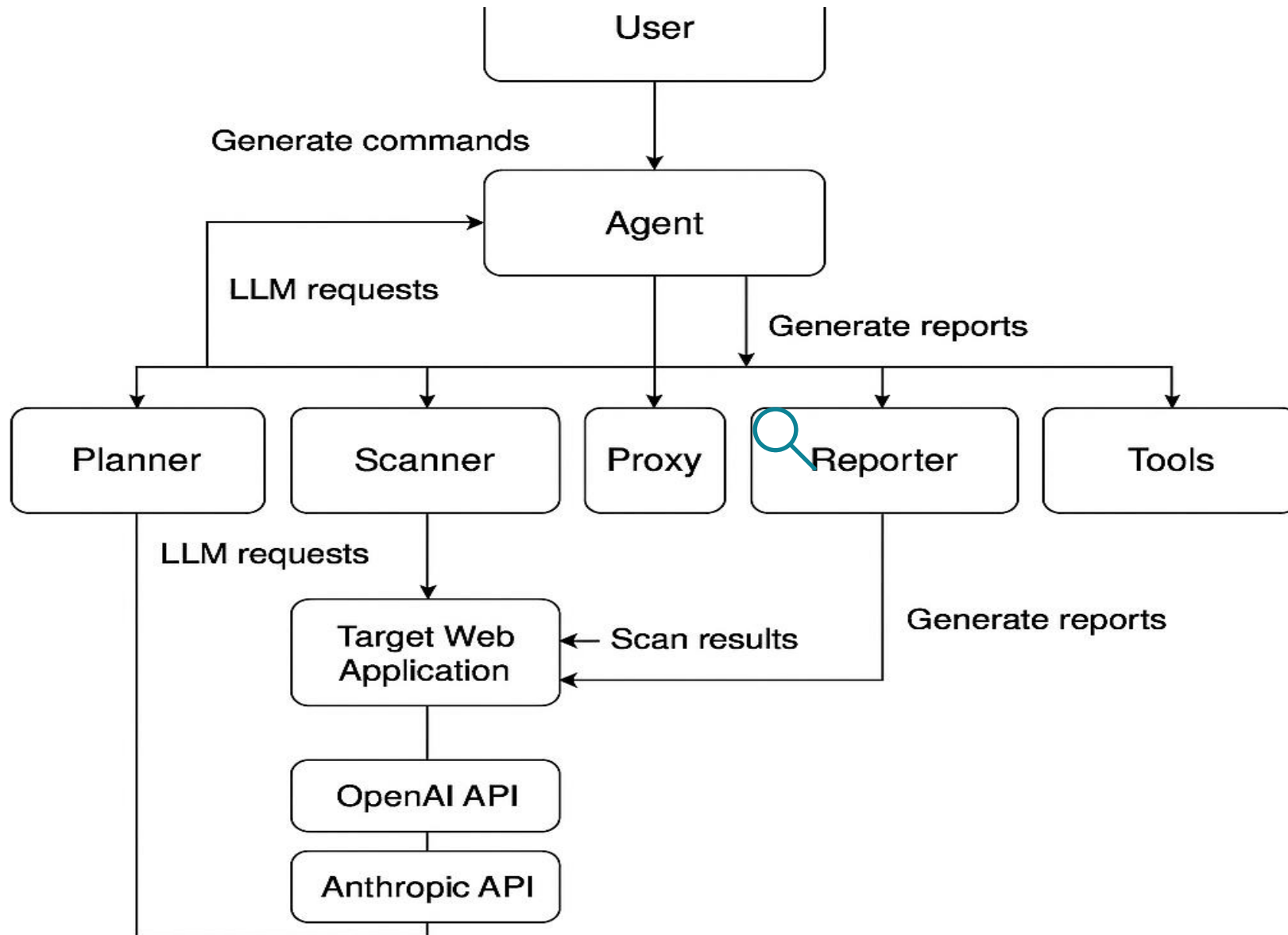
Detailed, actionable reporting with LLM-generated fixes

- ❑ system will not only find vulnerabilities but also explain them in detail and suggest possible fixes
- ❑ It doesn't just say "*SQL Injection found*" it explains what it is, where it happened, how it can be exploited, and how to fix it
- ❑ the LLM's analyzes the scan results and generates human-readable, actionable recommendations tailored to the specific issue

Intelligent, context-aware crawling & analysis

- ❑ understand the structure, purpose, and behavior of a website instead of blindly scanning every page
- ❑ AI's natural language understanding (NLU) to analyze web content intelligently, prioritize critical areas. AI helps the scanner understand what each page does:
 - › E.g. A shopping cart page? Test for SQL injection and CSRF
 - › An API endpoint? Test for broken authentication and IDOR

System Architecture

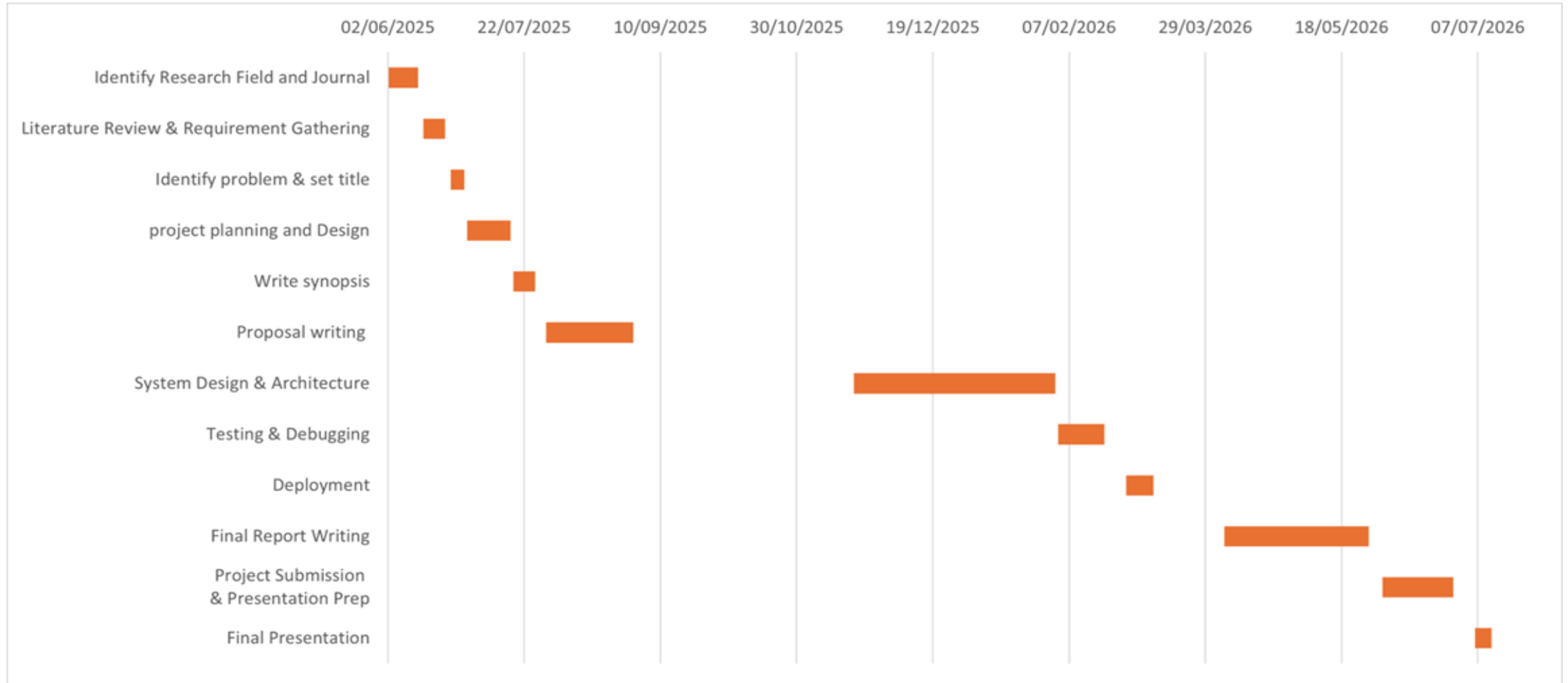


- ✓ The User sends a scan command to the Agent.
- ✓ The Agent requests a strategy from the Planner.
- ✓ The Planner uses LLM APIs to design an intelligent scan plan.
- ✓ The Agent directs the Scanner (and Tools) to execute the plan.
- ✓ The Scanner probes the Target Web Application, while the Proxy monitors traffic.
- ✓ Raw results are sent back to the Agent.
- ✓ The Agent forwards data to the Reporter to generate a final report.
- ✓ The User receives the comprehensive vulnerability report.

CONCLUSION AND FUTURE ENHANCEMENT

- ❖ The development of EvDeX demonstrates the practical value of integrating Large Language Models (LLMs) with advanced web vulnerability scanning techniques.
- ❖ By combining intelligent fuzzing, context-aware crawling, autonomous verification, and detailed LLM-generated reporting
- ❖ within a single command-line interface (CLI), EvDeX addresses a significant gap in the usability and effectiveness of traditional vulnerability scanners
- ❖ Although EvDeX achieves its current objectives as a CLI-based tool
- ❖ Future development will focus on improving usability, performance, and coverage.
- ❖ Planned enhancements include integrating a Graphical User Interface (GUI) for better accessibility, expanding support for API and cloud security testing
- ❖ Incorporating real-time threat intelligence to stay updated on emerging vulnerabilities

WORK PLAN (Gantt Chart)



BUDGET

‘EvDeX-Scan’: A modular gpt-4 Powered Web Scanner					
Item	Quantity	Days	Pages	Cost (ZMW)	Total (ZMW)
Laptop	1				0
Internet (research/testing)		90		10	900
Software tools				0	0
Printing & stationary			30	3	350
Miscellaneous				150	150
API Costs	OpenAI / Anthropic tokens			120	240
					1640

References

- [1] Babaey et al, "GenXSS: An AI-Driven Framework for Automated Detection of XSS Attacks in WAFs," in SoutheastCon 2025, 2025, pp. 1519–1524.
- [2] A et al Stafeev, "YURASCANNER: Leveraging LLMs for Task-driven Web App Scanning," Network and Distributed System Security Symposium (NDSS), 32nd Annual, feb 2024.
- [3] S. Varghese, and R. Kurian, "Identifying Vulnerabilities in a Website Using Uniscan and Comparing Uniscan, Grabber, Nikto," in National Conference on Emerging Computer Applications (NCECA), 2021, pp. 225–229.
- [4] P. Chand et al, "Vulnerability Scanner Build a Tool that Scans a System Forpotential Vulnerability," International Journal for Modern Trends in Science and Technology, vol. Volume 10, no. Issue 02 (10(02)), pp. 143–150, 2024.
- [5] Yoshihara, K and Takahashi, K., "A Simple Method for Unsupervised Anomaly Detection: An Application to Web Time Series Data," PLOS ONE, vol. 17, no. 1, p. e0262463, 2022.